AOU
الجامعة العربية المفتوحة
Arab Open University
Faculty of Computer Studies

TM311
Information Security

Final Examination
Spring Semester 2024/2025

Date: 11/June/2025

Number of Exam Pages: 5 (including this cover sheet)	**Time Allowed:** 3 Hours

Instructions:

- Total Marks: **100**
- This exam consists of **3** parts.
- **ALL questions** must be answered in the External Answer booklet.
- Be sure you write your **name and ID** on the External Answer booklet.
- **Calculators** are **NOT** allowed.

AOU EXAM PAPER

CamScanner

PART 1: Multiple Choice Questions [20 Marks]

Questions 1 (2 marks/each):

1. **Which of the following malware types is known for encrypting data and demanding payment to restore access?**
   a) Adware
   b) Ransomware
   c) Trojan Horse
   d) Worm

2. **Which firewall type is specifically designed to relay traffic between a user and an application server?**
   a) Packet-filtering firewall
   b) Stateful inspection firewall
   c) Application-level gateway
   d) Circuit-level gateway

3. **What icon indicates that a web browser is using HTTPS?**
   a) Shield icon
   b) Padlock icon
   c) Key icon
   d) Lock-open icon

4. **What does the 'R' in STRIDE stand for?**
   a) Risk
   b) Redirection
   c) Repudiation
   d) Resolution

5. **Which of the following is NOT a component required in a GDPR-mandated PIA?**
   a) A description of the processing operations
   b) An assessment of the risks to the rights and freedoms of data subjects
   c) A plan for achieving maximum profitability
   d) Measures to address the risks, including safeguards and security measures

6. **What is the relationship between risk, vulnerability, and threat in the context of threat modeling?**
   a) Risk = Threat × Vulnerability
   b) Risk = Vulnerability ÷ Threat
   c) Risk = Threat − Vulnerability
   d) Risk = Threat × Exploit

CamScanner

7. **What risk level should be assigned to privacy risks that must be "absolutely avoided or significantly reduced"?**
   a) Very low
   b) Low
   c) High
   d) Very high

8. **Which of the following certifications is targeted at individuals responsible for guarding protected health information (PHI)?**
   a) Certified Information Privacy Professional (CIPP)
   b) Certified Information Security Manager (CISM)
   c) HealthCare Information Security & Privacy Practitioner (HCISPP)
   d) Certified Information Privacy Manager (CIPM)

9. **What is the main objective of security event logging?**
   a) To enhance system performance
   b) To record unauthorized access attempts and anomalies
   c) To improve user experience
   d) To reduce network traffic

10. **What should be the organization's first action when a privacy incident involving PII occurs?**
    a) Inform the media immediately
    b) Notify affected individuals and relevant authorities
    c) Delete all data related to the breach
    d) Wait for the legal department's advice

PART 2: Short Answer Questions [30 Marks]

P2-Q1 [5 marks]: What is the role of intrusion detection systems (IDS) in network security?

P2-Q2 [5 marks]: What is the primary benefit of using HTTPS for online transactions?

P2-Q3 [5 marks]: Why is threat modeling done in the design phase of the SDLC?

P2-Q4 [5 marks]: List three common vulnerabilities identified in threat modeling?

P2-Q5 [5 marks]: 2. What is the main purpose of role-based privacy training?

P2-Q6 [5 marks]: What are the main goals of conducting an external security audit?

CamScanner

PART 3: Problem Solving Questions [50 Marks]

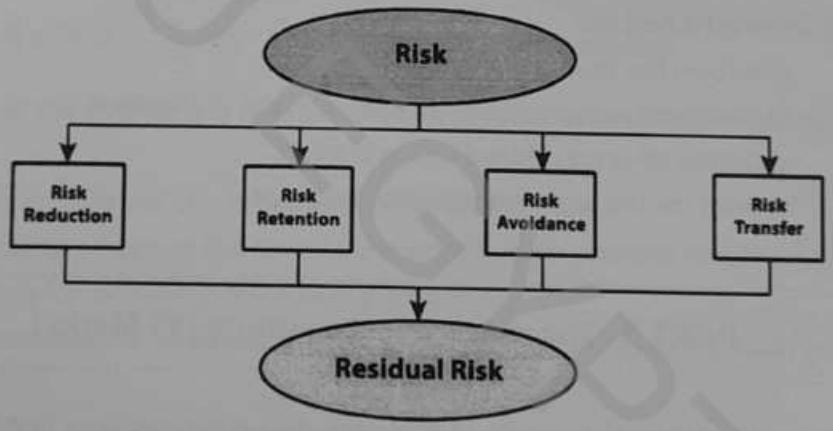
P3-Q1 [8 marks]: Scenario: Security Event Logging in a Financial Institution.

A financial institution needs to improve its security event logging to detect unauthorized access attempts to its online banking platform. Identify the key logs the institution should prioritize and suggest actions the IT team should take to respond to suspicious activities detected in these logs.

P3-Q2 [10 marks]: Scenario of a Post-Incident Activity for a Retail Company.

After experiencing a ransomware attack, a retail company has restored its systems and resumed operations. With respect to the post-incident activity phase, what steps should the company take to analyze the breach, improve security, and ensure that lessons learned from the attack are incorporated into future incident response plans?

P3-Q3 [5 marks]: Based on the options for risk treatment in the following figure, discuss which risk treatment strategy would be most appropriate for an organization facing a *high-probability* but *low-impact* event such as frequent minor IT system outages. Justify your choice.



P3-Q4 [20 marks]: The image below shows different rule sets for a packet-filtering firewall. Answer the following questions based on the provided rule sets:

CamScanner

Rule Set A					
action	ourhost	port	theirhost	port	comment
block	*	*	SPIGOT	*	we don't trust these people
allow	OUR-GW	25	*	*	connection to our SMTP port

Rule Set B					
action	ourhost	port	theirhost	port	comment
block	*	*	*	*	default

Rule Set C					
action	ourhost	port	theirhost	port	comment
allow	*	*	*	25	connection to their SMTP port

Rule Set D						
action	src	port	dest	port	flags	comment
allow	{our hosts}	*	*	25		our packets to their SMTP port
allow	*	25	*	*	ACK	their replies

Rule Set E						
action	src	port	dest	port	flags	comment
allow	{our hosts}	*	*	*		our outgoing calls
allow	*	*	*	*	ACK	replies to our calls
allow	*	*	*	>1024		traffic to nonservers

P3-Q4-1 [10 marks] Explain how Rule Set A provides security to the network. Identify the role of each rule and the specific threat it mitigates.

P3-Q4-2 [10 marks] Compare Rule Set B and Rule Set C in terms of their effectiveness for controlling SMTP traffic. Which rule set provides a more restrictive approach, and why?

P3-Q5 [7 marks]: You are tasked with conducting a risk assessment for a cloud-based service provider. Explain how you would use both quantitative and qualitative methods to provide a comprehensive assessment.

End of questions

CamScanner